

Project Glass · Post-Remediation Pen-Test Report

Target `glass.jiocommerce.io` · Tested 2026-05-04 · Scope passive recon (HTTP, headers, asset graph, exposed-path probes) · Spec `docs/glass-security-spec.md`

Result · 6 of 7 findings closed. The two CRITICAL findings (bypassable client-side gate, published password hash) and both HIGH findings (missing security headers, wildcard CORS) are fixed and verified in production. One MEDIUM (third-party JS) is deferred to Step 2 by design — it is build-pipeline work, not a security fix. The site is no longer in the “treat as public” category. Estimated header posture A+

FINDINGS · SEVERITY-ORDERED · STATUS AS OF 2026-05-04

\$	SEV	FINDING	VERIFICATION	STATUS
3.1	CRIT	Client-side gate bypassable · workspace HTML shipped pre-auth	<code>curl / → 401</code> · body 4,075 B challenge only · 0 workspace text leaks · all deep routes 401	Closed PR #63
3.2	CRIT	SHA-256 password hash published in <code>auth.js</code> line 3 · offline-bruteforce-able	0 hex hashes in any served asset · <code>/auth.js → 401</code> (deleted)	Closed PR #63
3.3	HIGH	Zero security headers beyond HSTS · no CSP, X-Frame-Options, Referrer-Policy, etc.	All 8 headers present · CSP <code>frame-ancestors 'none'</code> · X-Frame DENY · COOP/CORP same-origin · HSTS preload	Closed PR #63
3.4	HIGH	Wildcard <code>Access-Control-Allow-Origin: *</code> on confidential HTML	ACA0: null confirmed · including with <code>Origin: https://evil.example</code> request header	Closed PR #63
3.5	MED	Third-party JS in production · <code>cdn.tailwindcss.com</code> , Google Fonts	Still loaded · CSP whitelists explicitly · supply-chain risk persists until self-host	Deferred Step 2
3.6	MED	<code>robots.txt</code> body leaks “Internal property · Fynd × Reliance Retail” comments	Stripped · file is now <code>User-agent: * / Disallow: /</code> only · 0 comment lines	Closed PR #66
3.7	LOW	Hygiene cluster · no <code>security.txt</code> , HSTS lacks preload, autocomplete missing	<code>/.well-known/security.txt</code> RFC 9116 valid · HSTS includes <code>preload</code> · <code>autocomplete="off"</code> on form	Closed PR #63 + #66

- DEFENCE-IN-DEPTH SIDE-EFFECTS (POSITIVE)

 - Probes for `.env`, `.git/config`, `package.json`, `.DS_Store`, `middleware.ts`, `lib/auth.ts` all return 401 — middleware fires before the static-file 404 handler. Adversaries can no longer fingerprint file existence by status code.
 - Cookie tampering (Cookie: `glass_v1=invalid`) → 401. Replay attacks blocked by HMAC signature verification.
 - TRACE blocked (405); other methods return 401 from the gate.
- RESIDUAL SURFACE (ACCEPTABLE / OUT OF SCOPE)

 - The access phrase itself · social-engineering / phishing risk, not a code issue.
 - Vercel dashboard account compromise · insider threat, out of scope for this spec.
 - Third-party JS supply chain · §3.5 above; Step 2 closes it.
 - OPTIONS / returns 401 (was 204) · harmless since site has no public APIs needing CORS preflight.

VERIFICATION TRANSCRIPT · REPRESENTATIVE

```
$ curl -s -o /dev/null -w "%{http_code}\n" https://glass.jiocommerce.io/
401 # pre-fix: 200 with full workspace HTML
$ curl -sI https://glass.jiocommerce.io/ | grep -ciE "x-frame|content-security|referrer-policy|permissions-policy|cross-origin|x-content-type"
6 # pre-fix: 0
$ curl -sI -H "Origin: https://evil.example" https://glass.jiocommerce.io/ | grep -i access-control
access-control-allow-origin: null # pre-fix: *
$ curl -s https://glass.jiocommerce.io/ | grep -oE '[0-9a-f]{64}' | wc -l
0 # pre-fix: 1 (the published SHA-256 hash)
$ curl -s https://glass.jiocommerce.io/.well-known/security.txt | head -1
Contact: mailto:security@fynd.com # pre-fix: 404
```